

Plateforme de commande de repas sur campus

ritoto-campus.com | api.ritoto-campus.com

À l'attention de :

Google LLC — Équipe de vérification OAuth

Google Cloud Platform

Identity & Access Management

Objet : Description de l'utilisation de l'API Google Sign-In (OAuth 2.0) — Application Ritoto Express

Madame, Monsieur,

Nous vous adressons le présent document en réponse à la demande de vérification de notre application dans le cadre de la configuration de l'authentification via Google OAuth 2.0. Ce document décrit de manière précise et transparente la nature de notre application, les données que nous sollicitons auprès de vos services, ainsi que l'usage exclusif que nous en faisons.

1. Présentation de l'application

Ritoto Express est une plateforme numérique de commande de repas destinée aux étudiants d'un campus universitaire. Elle permet aux étudiants de consulter un menu, composer et passer des commandes en ligne, effectuer un paiement mobile, puis suivre l'état de leur commande en temps réel jusqu'à la livraison dans leur salle de cours.

La plateforme est accessible à l'adresse **<https://ritoto-campus.com>** et s'appuie sur une API REST sécurisée hébergée à **<https://api.ritoto-campus.com>**. Elle est destinée à un usage interne au campus et s'adresse à quatre catégories d'utilisateurs : les étudiants, les chefs de secteur, les livreurs et les administrateurs.

2. Raison de l'intégration de Google Sign-In

Nous avons intégré Google Sign-In pour offrir aux étudiants une alternative simple et sécurisée à la création d'un compte par email et mot de passe. La majorité de notre public cible possède déjà un compte Google via leur adresse universitaire. Cette intégration leur permet de s'inscrire et de se

connecter sans avoir à mémoriser un mot de passe supplémentaire, tout en bénéficiant de la sécurité que Google garantit sur ses comptes.

Google Sign-In est utilisé uniquement comme mécanisme d'identification. Il ne remplace pas notre système de gestion interne des utilisateurs : chaque compte reste enregistré dans notre propre base de données PostgreSQL avec les informations complémentaires spécifiques au campus (matricule étudiant, numéro de téléphone, secteur).

3. Données sollicitées et justification de chaque permission

Notre application demande uniquement les permissions strictement nécessaires à l'identification de l'utilisateur. Le tableau ci-dessous détaille chaque donnée sollicitée et son utilisation précise dans notre système.

Donnée demandée	Scope Google	Utilisation dans Ritoto Express
Adresse email	email	Sert d'identifiant unique dans notre base de données. Elle est également utilisée pour envoyer les notifications de commande (confirmation, statut, réinitialisation de mot de passe).
Prénom et nom	profile	Pré-remplissage du formulaire d'inscription. L'utilisateur peut les modifier avant de finaliser la création de son compte. Ces informations apparaissent dans l'interface (initiales dans l'avatar, nom complet dans les commandes).
Identifiant Google (sub)	openid	Stocké dans notre base de données pour identifier de manière unique un compte Google lors des connexions suivantes, même si l'utilisateur change son adresse email Google.
Photo de profil	profile	Affichée dans la barre de navigation de l'application comme avatar personnalisé. Son utilisation est purement cosmétique. L'URL de la photo est stockée, mais l'image elle-même n'est pas téléchargée ni hébergée sur nos serveurs.

Nous ne demandons aucun accès aux contacts, à l'agenda, aux emails, aux fichiers Google Drive, ni à aucune autre ressource de l'utilisateur. Notre application n'effectue aucune action au nom de l'utilisateur sur les services Google.

4. Description technique du flux d'authentification

Le flux d'authentification est entièrement conforme aux recommandations de Google pour les applications web. Il se déroule en quatre étapes :

1. L'utilisateur clique sur le bouton « Continuer avec Google » sur la page de connexion ou d'inscription. La bibliothèque `@react-oauth/google` (version officielle de Google) ouvre la fenêtre de sélection de compte Google.
2. Après consentement de l'utilisateur, Google retourne un jeton d'accès (*access token*) à notre frontend.
3. Notre frontend envoie ce jeton à notre API backend (`POST /api/auth/connexion-google/`). Le backend vérifie le jeton auprès des serveurs Google via la bibliothèque officielle `google-auth` (Python). Si le jeton est invalide ou expiré, la demande est rejetée immédiatement.
4. Si le jeton est valide, notre backend cherche si un compte existe déjà avec cet email ou cet identifiant Google. Dans l'affirmative, l'utilisateur est connecté et reçoit notre propre jeton d'authentification (DRF Token). Dans la négative, l'utilisateur est redirigé vers le formulaire d'inscription avec ses informations pré-remplies.

Le jeton Google n'est pas stocké sur nos serveurs. Il est utilisé une seule fois pour la vérification, puis immédiatement abandonné. Notre système émet ensuite son propre token d'authentification pour gérer les sessions.

5. Protection des données et conformité

Les données issues de Google Sign-In sont traitées avec le même niveau de protection que les données saisies manuellement dans nos formulaires. Plus précisément :

- Toutes les communications entre le navigateur, notre frontend et notre API sont chiffrées en TLS 1.2 minimum (certificats Let's Encrypt, renouvelés automatiquement tous les 90 jours).
- Les données sont stockées dans une base de données PostgreSQL hébergée sur un VPS dédié. La base n'est pas accessible depuis l'extérieur du réseau Docker interne.
- Aucune donnée personnelle n'est partagée avec des tiers, revendue, ou utilisée à des fins publicitaires.
- L'adresse email et le nom de l'utilisateur sont utilisés exclusivement pour le fonctionnement de la plateforme de commande (identification, suivi de commande, notifications transactionnelles).
- Les utilisateurs peuvent demander la suppression de leur compte et de l'ensemble de leurs données à tout moment en contactant l'administration.

6. Audience et nature de l'application

Ritoto Express est une application à usage interne, destinée exclusivement aux membres d'un campus universitaire (étudiants, personnel de restauration). Elle n'est pas ouverte au grand public et ne fait pas l'objet de démarches d'acquisition d'utilisateurs à large échelle.

Le nombre d'utilisateurs est limité à la population du campus. L'authentification Google est proposée comme option de confort, en complément de l'inscription classique par email et mot de passe qui reste disponible.

Nous restons disponibles pour fournir tout document complémentaire, démonstration de l'application, ou précision technique que votre équipe jugerait nécessaire dans le cadre du processus de vérification. Nous nous engageons à respecter scrupuleusement les politiques d'utilisation des API Google et à informer nos utilisateurs de manière transparente sur le traitement de leurs données.

Nous vous remercions de l'attention portée à notre demande et nous tenons à votre entière disposition.

Veuillez agréer, Madame, Monsieur, l'expression de nos salutations distinguées.

Cotonou, le 23 mars 2026

L'Équipe Ritoto Express

Administration de la plateforme

ritoto-campus.com

contact@ritoto-campus.com